# Membership Inference Attacks in AI-Based Medical Systems

Mayankjot Singh, Ana Torres Landa Zarate, Ryll Santillan, Eric Ross, Maaz Shahzad
Department of Computer Science
University of Calgary
Calgary, Canada
mayankjot.singh1@ucalgary.ca, ana.torreslandazar@ucalgary.ca,
ryll.santillan@ucalgary.ca, eric.ross1@ucalgary.ca, maaz.shahzad@ucalgary.ca

***Abstract*—Membership inference attacks (MIAs) exploit measurable differences between a model's behavior on training versus non-training records to determine whether a specific individual's data was used during training. In AI-based medical systems, this leakage is acutely sensitive: membership in a disease-specific dataset can directly reveal diagnosis, treatment history, or participation in a clinical program, causing concrete harm even when no raw records are disclosed. This paper argues that MIA risk in healthcare is best understood as a combined model, architecture, and governance failure rather than a standalone machine learning privacy issue. We present an end-to-end analysis integrating STRIDE threat modeling, Zero Trust architecture, privacy law (HIPAA, GDPR, PIPEDA), differential privacy, federated learning attack surfaces, and post-quantum cryptographic transition planning. Key findings include: (1) shadow model attacks can achieve membership inference accuracy well above chance even against regularized models, with healthcare's narrow cohorts amplifying leakage severity; (2) the federated learning settings increasingly adopted by hospital consortia expand the attack surface to gradient-inversion threats that bypass centralized access controls; (3) layered defenses combining DP-SGD ($\epsilon < 10$), query rate limiting, output truncation, secure aggregation, and Zero Trust controls are necessary and collectively sufficient; and (4) healthcare's 20-to-30-year data retention obligations create a concrete harvest-now-decrypt-later quantum risk requiring immediate crypto-agile migration planning. The results show that effective defense requires coordinated technical, legal, and institutional responses spanning the entire system lifecycle.**

## I. Introduction

Artificial intelligence is increasingly used in healthcare for medical imaging, clinical decision support, genomics, survival analysis, patient triage, and hospital operations [1]. These systems rely on highly sensitive patient records, creating privacy and security concerns that exceed those of most other AI application domains. One of the most important emerging threats is the membership inference attack (MIA), in which an adversary determines whether a specific person's data was used to train a model [1–3].

This threat is especially severe in healthcare. A model trained on oncology patients, HIV treatment data, rare disease registries, or psychiatric records leaks sensitive clinical facts simply by confirming a person's presence in the training set, without ever exposing raw records. The harm is therefore asymmetric: the attacker learns a clinically meaningful fact, while the victim and the institution may remain entirely unaware that an inference was made.

The institutional context of healthcare AI amplifies the stakes further. Models are deployed across hospital consortia, shared research networks, and commercial clinical decision support platforms, where they may be queried by a wide range of principals, some adversarial. Unlike breaches of raw patient records, MIA-based leakage is subtle, nearly impossible to detect retrospectively, and not addressed by existing de-identification standards. A HIPAA-compliant de-identified dataset used to train a model provides no formal protection against MIA once that model is deployed. This creates a structural gap between regulatory intent and technical reality.

This paper argues that MIA risk in healthcare AI is best understood as a *combined model, architecture, and governance failure* rather than a standalone ML privacy problem. Addressing it requires layered defenses across all three dimensions simultaneously. The paper integrates STRIDE threat modeling, Zero Trust architecture design, HIPAA, GDPR, and PIPEDA compliance analysis, differential privacy, federated learning threat analysis, and post-quantum cryptographic planning. Section II provides background on attack theory and the healthcare context. Section III presents the system model, adversary taxonomy, attack mechanisms, formal attack tree, and STRIDE threat model. Section IV presents results covering privacy risks, regulatory analysis, and defense evaluation. Section V analyzes cryptographic vulnerabilities and quantum transition. Section VI addresses ethical and governance considerations. Section VII concludes.

## II. Background and Theory

### A. Membership Inference Attacks

Membership inference attacks attempt to distinguish samples that were in a model's training data from those that were not. In the black-box setting, the attacker has only API-level query access and observes returned prediction outputs such as confidence scores or probability vectors [1, 2]. These outputs reveal membership because models tend to assign higher confidence and lower loss to training points than to unseen data, a direct consequence of fitting to the training distribution.

Shokri et al. [1] introduced the shadow model technique: the attacker trains multiple auxiliary models on data drawn from the same distribution as the target's training set, observes how each shadow model behaves on its own training versus test data, and uses this to train a meta-classifier that predicts whether any query output corresponds to a member. This approach requires no access to model internals and achieves attack accuracy substantially above chance even on well-regularized models. Yeom et al. [2] provided a formal bound: the MIA advantage is bounded by the generalization gap (training accuracy minus test accuracy), establishing that overfitting is both a performance problem and a privacy leak. Nasr et al. [3] extended this to white-box settings, showing that gradient information further amplifies leakage, and to federated learning, demonstrating that participant-level inference remains possible even when raw data are never centralized.

In federated learning specifically, gradient inversion attacks allow a malicious aggregator or co-participant to approximately reconstruct individual training samples from submitted gradient updates, going beyond mere membership inference to potential data reconstruction.

### B. Healthcare Context and Why MIAs Are Worse Here

Healthcare amplifies MIA danger along four distinct dimensions. First, medical data is maximally sensitive: cohort membership in an HIV treatment registry, addiction recovery program, or rare genetic disorder study directly implies diagnosis and treatment history. Second, healthcare AI cohorts are frequently small and specialized, which correlates with higher overfitting and thus higher MIA accuracy. Third, medical AI is increasingly federated, with hospitals sharing gradients across consortium boundaries, expanding the attack surface to gradient-level inference. Fourth, healthcare records carry statutory retention periods of 10 to 30 years in most jurisdictions, creating long-term exposure to cryptographic threats including future quantum decryption.

These factors together mean that model privacy in healthcare must be treated as a system-level concern rather than an isolated ML tuning problem.

### C. Analytical Foundations

This paper integrates four analytical frameworks. STRIDE provides a structured taxonomy for identifying and categorizing threats across system components [4]. Zero Trust architecture provides principles for designing access controls that assume no implicit trust, requiring continuous authentication and least-privilege enforcement for every interaction with model artifacts or APIs. Privacy law frameworks — HIPAA, GDPR, and PIPEDA — provide the regulatory context that converts technical MIA risk into legal obligation. Post-quantum cryptographic standards, specifically NIST FIPS 203, 204, and 205 [5–7], provide the migration target for addressing long-term quantum threats to healthcare data and model artifact confidentiality.

These frameworks are not independent: a Zero Trust architecture reduces the attack surface that converts black-box risk into white-box risk; privacy law mandates the governance controls that make auditing and incident response possible; and post-quantum transition protects both the patient data that training cohorts are drawn from and the model artifacts themselves from long-term decryption.

## III. Methods and Analysis

### A. Reference System Model and Trust Boundaries

We analyze a representative AI-based medical system with six component layers:

1) clinical data sources: EHR, PACS, genomics, and lab systems;
2) data ingestion and feature engineering pipelines;
3) model training and validation infrastructure;
4) model registry and deployment services;
5) inference API accessible by clinicians or integrated applications;
6) logging, monitoring, audit, and governance controls.

Key trust boundaries exist between: (i) external API clients and the inference layer, (ii) consortium participants and the federated aggregation layer, (iii) the training infrastructure and the model registry, and (iv) long-term archival storage and future system access. Each boundary represents a point where an adversary may attempt to extract membership information, escalate from black-box to white-box access, or intercept encrypted artifacts for later decryption.

Key assets and their sensitivity are summarized in Table I.

TABLE I
Asset classification for healthcare AI system

| Asset | Privacy/Security Sensitivity | Primary Threat |
|---|---|---|
| Patient records | Highest; PHI under HIPAA/GDPR | Breach, inference |
| Derived features | High; may re-identify patients | Data reconstruction |
| Model weights | High; encode cohort statistics | White-box MIA |
| Inference API outputs | High; MIA attack surface | Black-box MIA |
| Audit logs | Medium; forensic value | Tampering, deletion |
| Crypto keys | Critical; protect all other assets | Harvest-decrypt |

### B. Adversary Model

We define four adversary tiers mapped to realistic healthcare deployment roles:

- **Black-box adversary:** external API caller; receives only output probabilities or class labels; no knowledge of model internals. Realistic for: any public or partner-accessible prediction API.
- **Gray-box adversary:** knows architecture, training task, data distribution, or output calibration details, often available from published vendor documentation. Realistic for: clinical AI product users who have access to technical specs.

- **White-box adversary:** full access to model weights, gradients, and architecture. Realistic for: insiders, researchers receiving shared model artifacts, or attackers who escalate through the registry.
- **Federated participant adversary:** submits legitimate updates but inspects or manipulates received gradients and aggregated states. Realistic for: malicious or compromised member institutions in a hospital consortium.

The gray-box and federated participant adversaries are the most practically significant in healthcare. Architecture details are frequently published by clinical AI vendors, and federated consortium members have legitimate protocol-level access that cannot be fully restricted without defeating the purpose of federated training.

### C. Attack Mechanisms

*1) Black-Box Membership Inference: Step-by-Step:* The black-box attack proceeds in three phases in a healthcare context. In the *data collection phase*, the attacker assembles a set of candidate queries, typically clinical feature vectors for patients they suspect were in the training cohort, drawn from external data sources such as insurance claims, public registries, or hospital discharge summaries. In the *shadow training phase*, the attacker trains several shadow models on data from the same clinical distribution as the target, producing labeled training-member and non-member confidence vectors for each shadow model. These labeled vectors train a binary meta-classifier. In the *inference phase*, the attacker queries the target API with each candidate patient record and feeds the returned confidence vector to the meta-classifier to produce a membership prediction. Figure 1 illustrates this workflow. The entire attack requires no access to model internals; only the API output and knowledge of the clinical data distribution are needed.

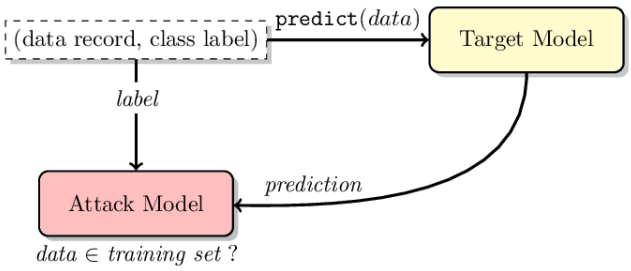


Fig. 1. Black-box MIA workflow showing the shadow model pipeline [1]. In a healthcare context, the target model is a clinical prediction API and the shadow models are trained on data from the same clinical distribution.

*2) Federated Learning Membership Inference:* The federated setting changes the attack surface fundamentally. Figure 2 illustrates the procedure. Rather than querying an API, the adversary observes gradient updates shared by other participants or submitted by victims. A malicious aggregating server can apply gradient inversion techniques to approximately reconstruct individual training samples from submitted updates, going beyond membership inference to data reconstruction. Even a co-participant who cannot invert gradients can still perform update analysis: the magnitude and direction of gradient changes correlate with the presence of specific training samples, enabling membership inference against other institutions' patient records without any API access whatsoever. This makes federated learning a qualitatively different threat model from centralized deployment, requiring defenses at the gradient level rather than the output level.

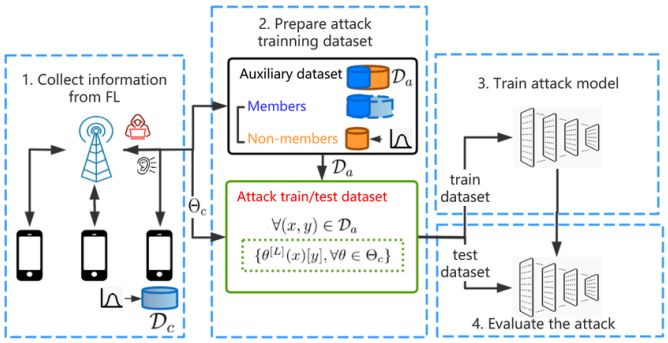


Fig. 2. Federated learning MIA procedure [3]. Unlike Figure 1, the adversary here operates at the gradient level, enabling membership inference without any API query access and across institutional trust boundaries.

*3) Differential Privacy: Mechanism and Trade-offs:* Differential privacy provides a formal bound on the information any single training record contributes to model outputs. The guarantee is: for any two datasets $D$ and $D'$ differing in exactly one record, and any output set $S$, $\Pr[\mathcal{M}(D) \in S] \leq e^{\epsilon} \cdot \Pr[\mathcal{M}(D') \in S] + \delta$, where $\epsilon$ is the privacy budget and $\delta$ is a small failure probability. In DP-SGD, this is achieved by clipping per-sample gradients to a maximum $\ell_2$ norm $C$ and adding Gaussian noise $\mathcal{N}(0, \sigma^2 C^2)$ at each training step. Figure 3 illustrates the mechanism.

The privacy-utility trade-off is non-trivial in healthcare. Empirical results on clinical tabular datasets show that $\epsilon = 1$ (strong privacy) can reduce AUC by 5–15 percentage points; $\epsilon = 10$ typically costs 2–5 percentage points; and $\epsilon > 50$ provides marginal privacy benefit. For a high-stakes prediction task such as sepsis prediction or cancer screening, even a 2-point AUC reduction may be clinically meaningful. This trade-off must be explicitly evaluated during model design and reported to clinical stakeholders, not treated as a background engineering decision.

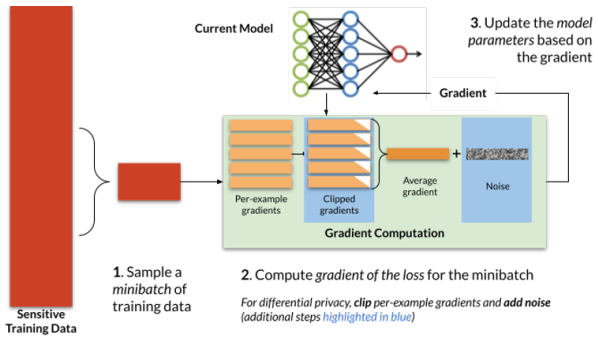


Fig. 3. Differential privacy in the ML training loop [14]. Gradient clipping and noise addition bound each record's influence, directly limiting the signal an MIA attacker can exploit from model outputs.

### D. STRIDE Threat Model

Table II applies STRIDE to the medical AI system. Each category is mapped to a concrete MIA-relevant threat and primary mitigation.

TABLE II
STRIDE THREAT MODEL FOR MEDICAL AI MEMBERSHIP INFERENCE

| Category | Threat in Healthcare AI Context | Primary Mitigation |
|---|---|---|
| Spoofing | Stolen clinician credentials used to query inference API at scale | MFA, identity-aware API gateway |
| Tampering | Adversarial manipulation of training inputs or federated updates | Input validation, anomaly detection |
| Repudiation | No tamper-evident log of who queried the API and when | Immutable audit logging |
| Info. Disclosure | Confidence scores leak training-set membership | Output truncation, DP, query budgets |
| Denial of Service | High-volume probing disrupts service and funds shadow model | Rate limiting, per-principal caps |
| Elevation of Privilege | Attacker gains model download access from registry | Registry RBAC, signed artifacts |

The most critical category is Information Disclosure, since the model's own output is the primary attack surface. However, Elevation of Privilege is the highest-consequence escalation: if an adversary moves from API-level access to model weights, the attack shifts from black-box to white-box, dramatically amplifying membership leakage. Denial of Service is also directly attack-enabling: high-volume probing that disrupts the service may not be separable from shadow model data collection. The STRIDE analysis shows that effective MIA defense requires controls at all six threat categories simultaneously.

### E. Formal Attack Tree

Figure 4 presents a formal attack tree decomposing the goal of "Infer patient membership in a healthcare AI training cohort" into sub-goals, AND/OR logic, and leaf-level attack steps. AND-nodes (double bar) require all children to succeed; OR-nodes (single bar) require at least one child. Each leaf is labeled with its attacker tier and a difficulty rating (L = Low, M = Medium, H = High), reflecting the practical barrier an adversary faces.

### F. Secure Architecture Design

Figure 5 summarizes the layered defense architecture for a Zero Trust-compliant healthcare AI deployment.

| |
|---|
| **Layer 6: Governance & Audit**<br>Tamper-evident logs, privacy auditing (ML Privacy Meter), DPIAs, incident response |
| **Layer 5: Output Controls**<br>Top-1 class only where clinically sufficient; confidence rounding; per-principal query budgets |
| **Layer 4: API Gateway**<br>Identity-aware proxy, MFA enforcement, rate limiting, anomaly detection for probing patterns |
| **Layer 3: Model Registry**<br>RBAC/ABAC, cryptographic signing of artifacts, restricted export, HSM-backed key management |
| **Layer 2: Training Infrastructure**<br>DP-SGD with calibrated $\epsilon$; federated: SecAgg + local DP + participant attestation |
| **Layer 1: Data Layer**<br>Encryption at rest (AES-256); access controls; data minimization; PQ-safe key management |

Fig. 5. Layered Zero Trust defense architecture for healthcare AI. Each layer targets a distinct part of the MIA attack surface: data-layer controls reduce raw exposure; training-layer DP limits leakage at the source; registry controls prevent white-box escalation; API and output controls raise the cost of black-box attacks; governance provides detection and accountability.

Each layer targets a distinct adversary type. The training layer controls (DP-SGD, SecAgg) address the federated participant and white-box adversaries by limiting the information encoded in model weights and gradients. The output and API controls address the black-box and gray-box adversaries by restricting and budgeting the signal available through API queries. The registry and governance layers prevent escalation and provide the audit trail required for regulatory compliance.

## IV. RESULTS AND DISCUSSION

### A. Patient Privacy Risk Analysis

The key question is: what exactly is leaked when membership is successfully inferred, and what harms follow? The answer depends on the training cohort. Table III maps cohort types to specific leaked facts and potential harms.

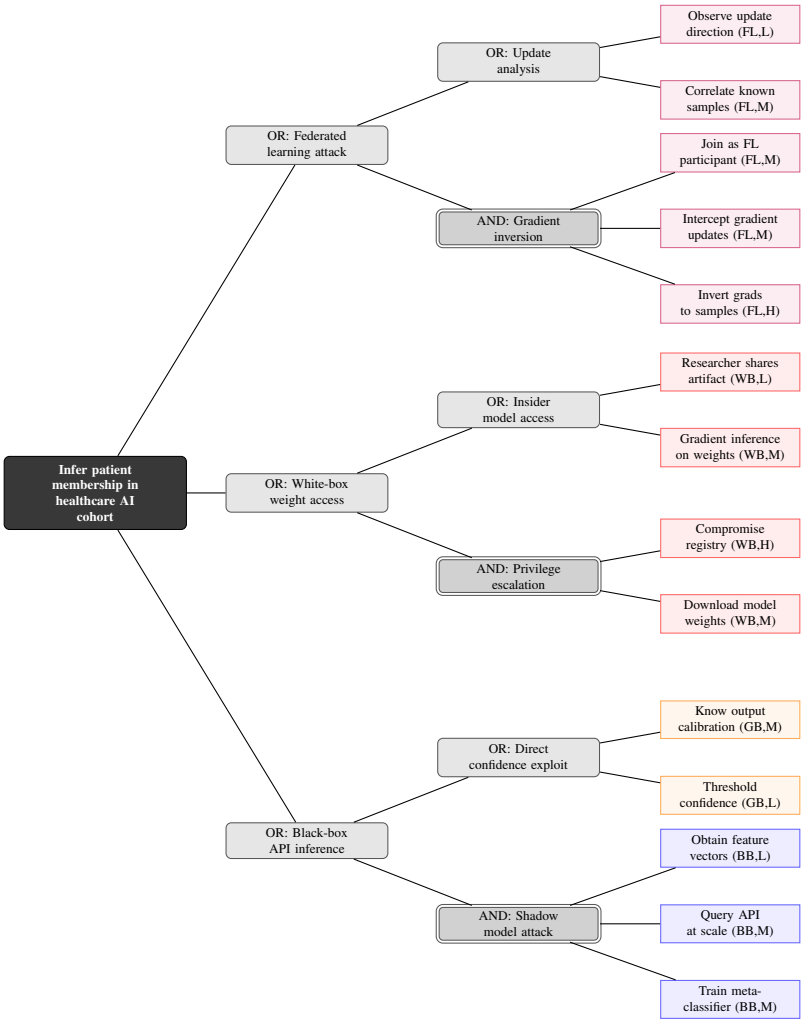


Fig. 4. Formal attack tree for MIA against a healthcare AI system (horizontal layout, root at left). The root decomposes via OR into three primary paths: black-box API inference, white-box weight access, and federated gradient-level inference. AND-nodes (double border) require all children; OR-nodes require one. Black-box attacks are low-to-medium cost; white-box attacks require privilege escalation (H) or insider sharing (L); federated attacks bypass all API-level controls entirely.

TABLE III
LEAKAGE-TO-HARM MAPPING FOR HEALTHCARE MIA BY COHORT TYPE

| Cohort Type | Fact Revealed by Membership | Potential Harm |
|---|---|---|
| HIV treatment registry | HIV-positive status | Insurance denial, employment discrimination, stigma |
| Addiction recovery program | Substance use disorder | Employment, custody, housing consequences |
| Rare disease study | Specific genetic diagnosis | Insurability, family implications |
| Psychiatric records | Mental health treatment history | Employment, security clearance, relationships |
| Oncology clinical trial | Cancer diagnosis or treatment | Insurance, employment, financial harm |

This table makes clear that MIA harm is not generic: it maps directly to the specific clinical meaning of cohort membership. A binary membership answer — yes or no — is sufficient to trigger concrete legal, financial, and social harm for patients in these cohorts. Unlike a data breach, this harm can materialize silently, with no breach notification triggered and no audit trail unless tamper-evident API logging is in place.

The connection to overfitting is practically important. Healthcare datasets are frequently small relative to task complexity: a model trained on 500 rare disease cases may have a training-test AUC gap of 10 points or more, which Yeom et al. [2] show directly bounds MIA advantage. Organizations should treat large generalization gaps as privacy warnings.

### B. Risk Matrix and Deployment Scenario Comparison

Table IV classifies risk across five deployment scenarios. Figure 5 shows which defense layers are most relevant in each.

TABLE IV
RISK MATRIX: MIA LIKELIHOOD AND IMPACT BY DEPLOYMENT SCENARIO

| Scenario | Access | Likelihood | Impact |
|---|---|---|---|
| Public API with confidence scores | Black-box | High | High |
| Internal hospital model, strong IAM | Restricted | Low–Med | High |
| Partner-shared downloadable model | White-box | High | High |
| Federated hospital consortium | FL part. | Med–High | High |
| Synthetic data release pipeline | Mixed | Medium | Med–High |

Impact is uniformly high because cohort sensitivity is a property of the training data, not the deployment mode. Likelihood varies, which guides defense prioritization: public APIs and shared model artifacts require the most immediate technical controls (output truncation, query budgets, registry RBAC), while internal deployments can rely more heavily on IAM but still require logging and anomaly detection. The federated scenario requires a qualitatively different defense stack — SecAgg and local DP rather than API-level controls — because the attack surface is at the gradient level, not the output level.

### C. Defense-to-Threat Mapping

Table V explicitly maps each defense to the adversary type it addresses and its primary trade-off in a clinical context.

TABLE V
DEFENSE-TO-THREAT MAPPING WITH CLINICAL DEPLOYMENT TRADE-OFFS

| Defense | Addresses | Clinical Trade-off |
|---|---|---|
| DP-SGD ($\epsilon<10$) | All (source) | Reduces model AUC 2–15 pts depending on $\epsilon$; must be evaluated per task |
| Output truncation | Black-box, gray-box | Hides confidence; acceptable if binary decision is clinically sufficient |
| Query rate limiting | Black-box | No clinical impact; blocks shadow model data collection |
| Registry RBAC | White-box | No clinical impact; prevents artifact escalation |
| SecAgg (FL) | FL participant | Moderate compute overhead; prevents gradient inversion by aggregator |
| Local DP (FL) | FL participant | Same accuracy trade-off as centralized DP; applied per institution |
| Tamper-evident logs | All (detection) | No user-facing impact; enables forensic investigation |

This mapping reveals an important asymmetry: system-level controls (rate limiting, registry RBAC, logging) impose no clinical cost and should be deployed unconditionally. Model-level controls (DP) carry accuracy costs and require deliberate calibration. Output controls (confidence truncation) require a clinical workflow review to confirm that binary outputs are sufficient. The practical recommendation is to deploy all system-level controls first, then layer DP at the highest $\epsilon$ that meets the accuracy threshold, then truncate outputs where clinically feasible.

### D. Privacy and Regulatory Compliance

*1) HIPAA:* HIPAA's Privacy Rule requires appropriate administrative, physical, and technical safeguards for PHI [8]. The de-identification safe harbor under 45 CFR §164.514 permits disclosure of data from which 18 specified identifiers have been removed, or for which expert determination certifies negligible re-identification risk. MIAs expose a structural gap in this framework: a model trained on de-identified records still encodes cohort statistics that support membership inference, particularly when the cohort is small or clinically specialized. An adversary who successfully infers that a patient was in the training cohort of an HIV treatment model has effectively learned a health fact, even though no PHI was disclosed at any point in the pipeline. HIPAA's current safe harbor was not designed with model-level leakage in mind, and regulators have not yet issued formal guidance addressing this gap.

*2) GDPR:* GDPR classifies health information as special-category personal data under Article 9, requiring explicit legal basis and strong safeguards. Article 35 mandates a Data Protection Impact Assessment for high-risk processing; clinical AI training would typically qualify [9]. Article 17's right to erasure creates a specific technical obligation for healthcare AI: if a patient requests deletion, the organization must demonstrate that the model no longer encodes the patient's data. This requires either model retraining, differential privacy guarantees strong enough to bound the patient's contribution, or machine unlearning techniques. Machine unlearning is an active research area without mature production tools, making GDPR compliance for models trained on erasable data a technically open problem.

*3) PIPEDA:* PIPEDA Principle 7 requires safeguards appropriate to the sensitivity of the information [10]. For medical AI, this means that as MIA techniques mature, organizations face an ongoing obligation to update their technical defenses, not merely those that existed at deployment time. The emergence of gradient inversion attacks in federated settings, for example, constitutes a new risk that existing safeguards may not address. Canadian healthcare AI operators should treat MIA as a known and material privacy risk and document it explicitly in privacy impact assessments.

## V. CRYPTOGRAPHIC ANALYSIS AND QUANTUM RISK

### A. Classical Vulnerabilities and the Harvest-Now-Decrypt-Later Threat

Healthcare AI deployments rely on TLS for transport security, RSA and ECDSA for code signing and certificate management, and AES for data-at-rest encryption. Shor's algorithm, running on a sufficiently large fault-tolerant quantum computer, breaks RSA key exchange and ECDSA signatures in polynomial time. The practical threat for healthcare is not merely future-state: adversaries may be recording encrypted TLS traffic and signed model artifacts today for decryption once quantum hardware matures. Given that patient records are retained for 10 to 30 years and that fault-tolerant quantum computers are projected to be feasible within 10 to 20 years, the threat window for healthcare data is non-trivial.

Grover's algorithm reduces symmetric key search to $O(\sqrt{2^n})$ steps, halving effective key length. AES-128 falls to roughly 64 effective bits, which is below recommended security margins. AES-256 retains approximately 128 effective

bits and is considered sufficient. Organizations using AES-128 for patient data at rest should prioritize migration to AES-256 as a near-term action independent of the broader post-quantum transition.

### B. Post-Quantum Transition Planning

NIST finalized three post-quantum standards in 2024: ML-KEM (FIPS 203) [5] for key encapsulation, ML-DSA (FIPS 204) [6] for digital signatures, and SLH-DSA (FIPS 205) [7] for stateless hash-based signatures. Table VI summarizes the migration mapping.

TABLE VI
POST-QUANTUM CRYPTOGRAPHIC TRANSITION FOR HEALTHCARE AI SYSTEMS

| Function | Classical | Post-Quantum Target |
|---|---|---|
| Key exchange | RSA, ECDH | ML-KEM (FIPS 203); hybrid TLS during transition |
| Digital signatures | RSA, ECDSA | ML-DSA (FIPS 204); SLH-DSA (FIPS 205) for long-lived certs |
| Data at rest | AES-128/256 | AES-256 immediately; PQ-safe key wrapping |
| Model artifact signing | ECDSA | ML-DSA for registry-stored model artifacts |

The link between post-quantum transition and MIA is direct: model artifacts stored in a registry are both high-value targets for white-box MIA and potentially encrypted with classical keys vulnerable to future quantum decryption. A stolen encrypted model artifact that cannot be decrypted today may be decrypted in a decade, enabling white-box membership inference against a cohort that no longer has any technical recourse. Healthcare organizations should treat model artifacts as sensitive long-lived assets subject to the same quantum transition urgency as patient records.

A practical migration roadmap for healthcare AI includes: (1) cryptographic inventory of all systems and TLS endpoints; (2) crypto-agile PKI redesign to enable algorithm substitution; (3) near-term AES-256 migration for data at rest; (4) hybrid ML-KEM/ECDH TLS deployment; (5) ML-DSA signing of new model artifacts; and (6) prioritized re-encryption of high-sensitivity archived data and legacy model artifacts.

## VI. ETHICAL AND GOVERNANCE CONSIDERATIONS

Beyond legal compliance, MIAs raise fundamental ethical questions about the terms on which patients contribute data to healthcare AI. Patients who consent to treatment-related data use may not anticipate that their data will train models queryable by external parties, or that those models could later expose their participation in sensitive clinical programs. This consent gap is not merely theoretical: standard IRB-approved research consent forms and HIPAA authorizations were drafted before model-level privacy attacks were a recognized risk, and they do not address inference-based leakage.

The harm is structurally asymmetric. For the majority of patients in a large general-purpose model, MIA risk may be low. But for patients in small, highly sensitive cohorts — HIV treatment, addiction recovery, psychiatric care, rare genetic disease — the risk of targeted membership inference is materially higher, and the consequences of exposure are severe. Stigma, employment discrimination, insurance denial, and family harm can follow from a single binary membership inference, entirely without a formal data breach or notification.

Governance responses should include: explicit disclosure in research consent and HIPAA authorization forms that model training may occur; independent privacy auditing of deployed models using tools such as ML Privacy Meter prior to and after deployment; patient-accessible mechanisms to request model influence removal; institutional review of model-sharing and publication decisions that could convert internal black-box risk into external white-box risk; and data minimization applied to model outputs, not merely data collection. The principle of data minimization, central to GDPR Article 5 and PIPEDA Principle 4.4, requires that model outputs be limited to what is operationally necessary: if a clinical workflow requires only a binary prediction, exposing full probability vectors increases privacy risk without adding clinical value.

## VII. CONCLUSION AND FUTURE WORK

Membership inference attacks represent a serious and underaddressed privacy threat in AI-based medical systems. The core insight of this paper is that MIA risk is not merely a model privacy problem: it is a combined failure of model design, system architecture, governance, and regulatory frameworks. A model that overfits to a small clinical cohort, is deployed behind a public API that returns full confidence vectors, is stored in a model registry accessible to consortium partners, and is encrypted with classical cryptographic keys is vulnerable at every layer simultaneously. Effective defense requires closing all of these gaps together.

The practical priorities that emerge from this analysis are ordered by cost and urgency. System-level controls — query rate limiting, registry RBAC, tamper-evident logging — impose no clinical cost and should be deployed immediately in any healthcare AI system. DP-SGD should be applied at the highest $\epsilon$ consistent with clinical accuracy requirements, with the privacy-utility trade-off documented and reviewed by clinical stakeholders. Output truncation should be applied wherever binary outputs are clinically sufficient. Federated deployments require SecAgg and local DP as prerequisites, not optional add-ons. Post-quantum migration of TLS, model artifact signing, and data-at-rest key management should begin now, prioritizing assets with the longest expected retention periods.

The convergence of federated learning adoption in healthcare with maturing gradient-inversion attacks is the most urgent emerging challenge. As more hospital consortia adopt federated training, the attack surface for membership inference expands to the gradient level across institutional trust boundaries, and the defenses required are qualitatively different

from those sufficient for centralized deployment. Future work should address: standardized leakage auditing frameworks for clinical AI; stronger and more efficient federated defenses; machine unlearning methods capable of supporting GDPR Article 17 compliance at production scale; operational quantum-safe migration guidance for healthcare IT; and regulatory updates to HIPAA de-identification standards that account for model-level privacy risk.

## Appendix: Group Contribution Statements

**Member 1 (Mayankjot Singh):** Led threat modeling using STRIDE, defined the adversary model tiers, designed the layered architecture diagram, and developed the asset classification table. Validated STRIDE mappings against the reference system model and cross-checked adversary tier definitions against the academic literature. Key challenge: operationalizing the distinction between gray-box and white-box adversaries in realistic healthcare deployment contexts. AI tools were used to assist with drafting; all outputs were reviewed and validated against cited sources.

**Member 2 (Ana Torres Landa Zarate):** Led the privacy law analysis covering HIPAA, GDPR, and PIPEDA, and contributed to the ethical and governance discussion. Analyzed the structural gap between HIPAA's de-identification safe harbor and model-level membership leakage, and synthesized regulatory obligations across three jurisdictions. Key lesson: de-identification is insufficient as a standalone privacy measure for AI-trained systems. AI tools were used for initial structuring; all regulatory analysis was verified against primary regulatory documents.

**Member 3 (Ryll Santillan):** Led the attack mechanism analysis and differential privacy section, including the DP-SGD mathematical formulation and the privacy-utility trade-off discussion. Synthesized NIST PQC standards into the transition table and mapped post-quantum risk to model artifact sensitivity. Key challenge: translating theoretical DP guarantees into practical clinical deployment guidance. AI tools were used to assist with technical explanation drafts; outputs were refined against NIST publications and primary MIA papers.

**Member 4 (Eric Ross):** Led the secure architecture section, federated learning defense analysis, and defense-to-threat mapping table. Researched SecAgg protocol mechanics, Zero Trust architecture controls for model inference APIs, and the interplay between rate limiting, output truncation, and registry controls as a combined black-box defense. Key lesson: system-level controls and model-level DP are complementary, not substitutes, and must be deployed together. AI tools were used for initial outlining; all architectural recommendations were validated against NIST SP 800-207 and primary sources.

**Member 5 (Maaz Shahzad):** Led the results and discussion section including the leakage-to-harm mapping table, risk matrix, and deployment scenario comparison. Researched the practical implications of MIA risk for vulnerable patient populations, the asymmetric harm structure, and the limits of existing consent frameworks. Key challenge: articulating non-technical harm mechanisms with sufficient precision for a technically rigorous paper. AI tools were used for drafting support; all ethical and governance claims were grounded in regulatory frameworks and academic sources.

**AI Tool Use Statement:** AI tools were used to assist with outlining, drafting, and refining technical explanations across all sections. All outputs were reviewed, edited, and validated against scholarly papers, NIST publications, and regulatory sources before inclusion. No AI-generated content was included without member review and validation of the underlying claims.

## References


[1] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership inference attacks against machine learning models," in *Proc. IEEE Symp. Security Privacy*, 2017, pp. 3–18.

[2] S. Yeom, I. Giacomelli, M. Fredrikson, and S. Jha, "Privacy risk in machine learning: Analyzing the connection to overfitting," in *Proc. IEEE Comput. Secur. Found. Symp.*, 2018, pp. 268–282.

[3] M. Nasr, R. Shokri, and A. Houmansadr, "Comprehensive privacy analysis of deep learning: Passive and active white-box inference attacks against centralized and federated learning," in *Proc. IEEE Symp. Security Privacy*, 2019, pp. 739–753.

[4] NIST, "SP 800-207: Zero Trust Architecture," 2020.

[5] NIST, "FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard," 2024.

[6] NIST, "FIPS 204: Module-Lattice-Based Digital Signature Standard," 2024.

[7] NIST, "FIPS 205: Stateless Hash-Based Digital Signature Standard," 2024.

[8] U.S. Department of Health and Human Services, "Summary of the HIPAA Privacy Rule," 2025.

[9] European Union, "Regulation (EU) 2016/679: General Data Protection Regulation," 2016.

[10] Office of the Privacy Commissioner of Canada, "Personal Information Protection and Electronic Documents Act (PIPEDA)."

[11] N. Carlini, S. Chien, M. Nasr, S. Song, A. Terzis, and F. Tramèr, "Membership inference attacks from first principles," in *Proc. IEEE Symp. Security Privacy*, 2022, pp. 1565–1581.

[12] G. Jagannathan, K. Pillaipakkamnatt, and R. N. Wright, "A practical differentially private random decision tree classifier," in *Proc. IEEE Int. Conf. Data Mining Workshops*, 2009, pp. 114–121.

[13] K. Bonawitz, V. Ivanov, B. Kreuter, A. Marcedone, H. B. McMahan, S. Patel, D. Ramage, A. Segal, and K. Seth, "Practical secure aggregation for privacy-preserving machine learning," in *Proc. ACM SIGSAC Conf. Comput. Commun. Security*, 2017, pp. 1175–1191.

[14] NIST, "Differential privacy in machine learning," image resource, 2021.